İTÜ

Security in Financial Information Systems

Trust Models and Identity Management

Dr. Şerif Bahtiyar
bahtiyars@itu.edu.tr

1

Motivation

Gizli belgeler sızdı: Dünyanın en zengin insanı 'Twitter ordusu' kurmuş!

Online alışveriş platformu Amazon'un CEO'su Jeff Bezos ve şirketin çıkarlarını korumak için bir 'Twitter ordusu' kurduğu ortaya çıktı.

https://www.hurriyet.com.tr/dunya/gizli-belgeler-sizdi-dunyanin-en-zengin-insani-twitter-ordusu-kurmus-41777354

2

Motivation

Hundreds of companies potentially hit by Okta hack

Hundreds of organizations that rely on Okta to provide access to their networks may have been affected by a cyber-attack on the company.

https://www.bbc.com/news/technology-60849687

3

Outline

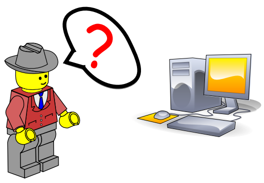
- Trust
- Trust and Security
- Trust Modeling
- Key Management and Key Distribution
- Identity Management

4

Introduction

Basic Question in Cyber Space?

- Can I believe what I read?
- What happens to the things I type?
- Who else has seen this?
- Are these really my results?



5

Trust Context

- philosophy
- psychology
- sociology

Human - Human

- computer science
- business

Human - Machine

- computer science

Machine - Machine

6

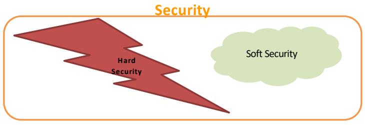
Trust and Security

General definition of security: Protection from danger and criminals.

Information security: Preservation of confidentiality, integrity, availability, authenticity, and accountability of information.

Hard Security: Uses traditional mechanisms and defines a security policy explicitly or implicitly.

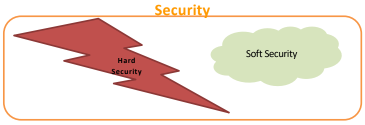
Soft Security: Uses social control mechanisms against misrepresentation of services, incorrect information, fraud, and etc.



7

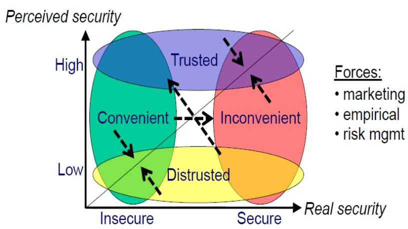
Trust and Security
Soft Security

- Social control mechanisms
- Impossible to define security policies for open -> common ethical norms instead of security policy.
- Protection Against (Josang):
  - low quality services
  - misrepresentation of services
  - incorrect information
  - fraud
- Enforced by collaborative mechanisms such as **trust** and reputation systems.



8

Trust and Security



Forces:
- marketing
- empirical
- risk mgmt

*Josang

Problem

Can I trust to the security system of a specific service based on my private needs?

9

Definition of Trust

Gambetta for Social Sciences

The subjective probability by which an individual, A, expects that another individual, B, performs a given action on which its welfare depends.

Grandison and Sloman for Computer Networks and Security

The firm belief in the competence of an entity to act dependable, securely and reliably within a specified context.

Massa for Online Social Networks

The judgment expressed by one user about another user, often directly and explicitly, sometimes indirectly through an evaluation of the artifacts produced by that user or her activity on the system.

10

Some Properties of Trust

- Subjective
- Context dependent (such as environment)
- Measurable
- History dependent
- Dynamic (time, event, … dependent) – learning and reasoning
- Composite property (reliability, dependability, honesty, security, …)

11

The Origin of Trust

≠

Real (Assumed) Fact

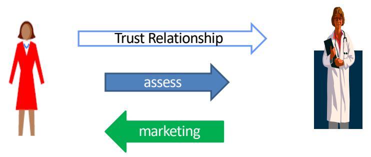
- **Characteristics:** crisp, frequenist
- **Formalisms:**
  - binary logic
  - quantum logic

Perceived Fact

- **Characteristics:** vague, fuzzy, uncertain
- **Formalisms:**
  - subjective probabilities
  - multi-valued logic
  - probabilistic logic

12

Where Does Trust Reside?



Trustor (trusting party)

- is a situation of dependence
- wants to assess and make decision about trustee (Josang)

Trustee (trusted party)

- is a situation of power and expectation to deliver
- wants to represent and put in a positive light own competence (Josang)

13

Some Trust Related Concepts

- Risk is an attribute of a decision alternative that reflects the variance of its possible outcames. It is present in a situation where the possible damage may be greater than the advantage that is sough. (Luhmann)
- Confidence is the accuracy or quality of trust where high confidence is more useful in making trust decisions. (Yan)
- Trustworthiness is a characteristic of the trustee, while trust is the trustor's willingness to engage in risky behaviour that stem from the trustor's vulnerability to the trustee's behavior. (Gefen)
- Trust Metric is an algorithm that uses the information of the trust network in order to predict the trustworthiness of unknown users. (Massa)

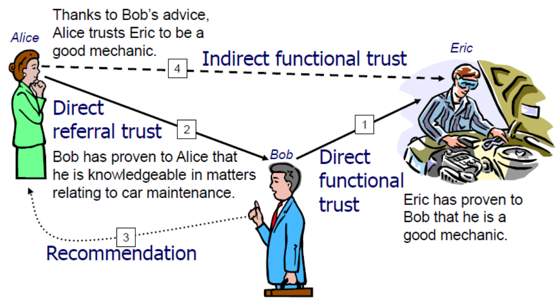
14

General Trust Models

- Direct Trust: takes into account direct experiences.
- Indirect (Transitive) Trust: depends on recommendations.
- Functional Trust: trusting entity x for scope y.
- Referral Trust: trusting x to recommend for scope y.

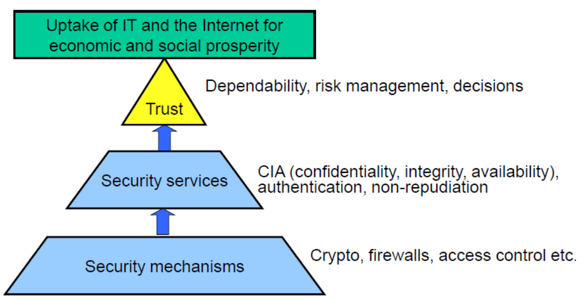
15

General Trust Models



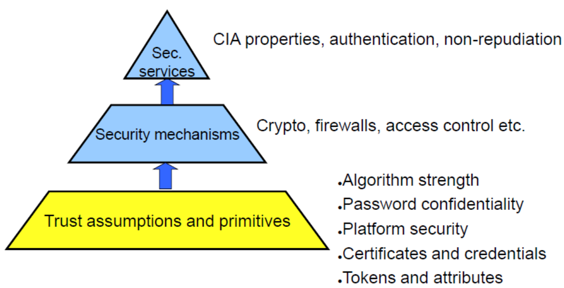
16

Trust as Security Layer



17

Trust as Assumptions and Primitives



18

Trust Modelling Approaches

- Probabilistic models
  - assigns a degree of confidence to a principal's ability to predict another principal's behavior
  - suitable for small scale networks

- Social networks
  - suitable for large scale networks

- Hybrid systems

19

Trust Measure

- Binary
  - trusted or not trusted
  - 1 or 0
- Discrete
  - strong trust, weak trust, less trust
  - -10 to 10
- Continuous
  - percentage (%)
  - probability (P(success))
  - belief

20

Trust Computation Models

- Summation or average
- Hidden Markov
- Bayesian models
- Discrete models
- Belief models
- Fuzzy models
- Flow models
- Others

21

Summation or Average Models

Summation

- score = ∑(positive) -∑(negative)

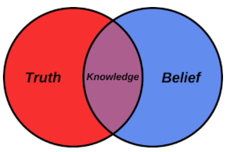
Average

- score = ∑(ratings)/N(ratings)

- Can be combined with sliding time windows
- Simple to understand
- Can give false impression of reputation

22

Belief Models



- Assumes a trust scope
- Two semantic variants of each trust scope
  - Functional, e.g. to be a good mechanic
  - Referral, e.g. to be a good at recommending mechanics
- Two topological types
  - Direct: Trust as a result of direct experience
  - Indirect: Trust as a result of second hand evidence

23

Flow Models

- Transitive iteration through graph
- Loops and arbitrarily long paths
- Source of trust can be distributed
  - evenly, e.g. early version of PageRank
  - discretely, e.g. current PageRank, EigenTrust
- Sum of trust can be
  - constant, e.g. PageRank
  - increasing with network size, e.g. EigenTrust

24

Some Applications

- Auction sites: www.ebay.com and www.amazon.com
- Expert sites: www.expertcentral.com
- Product reviews: www.epinions.com
- Medical systems: http://www.ratemds.com/
- Article postings: www.slashdot.com
- Education: us.ratemyteachers.com
- Entertainment: www.citysearch.com
- E-commerce: www.virtualratings.com

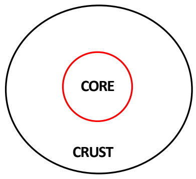
25

An Hybrid Trust Model Approach

Core-Crust Trust Modeling Approach

- A hybrid modeling approach for formal representation of trust in an entity
- Core-Crust Modeling Approach (CCMA)

CORE
- Common to all entities in an environment
- Good for security

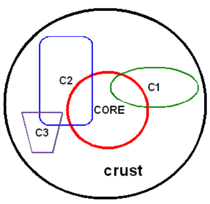


CRUST
- Specific to some entities
- Good for trust

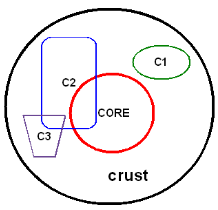
26

An Hybrid Trust Model Approach

- A crust model is connected to core model with at least one parameter.
- The connection is represented with an intersection of two models.



A correct example for CCMA



An incorrect example for CCMA

27

Trusted Computing

- Trusted Platform Module (TPM)
  - An industry standard developed by Trusted Computing Group
  - A hardware module
  - At the heart of a hardware/software approach of trusted computing
  - Trusted Computing (TC) is used to refer such hardware and software
- TC employs a TPM chip in personal computer motherboard or a smart card or integrated into the main processor, together with HW and SW that in some sense has been approved or certified to work with the TPM.

28

Trusted Computing

- Trusted Computing Approach: TPM generates keys that it shares with vulnerable components that pass data around the system. The keys can be used to encrypt the data flow through the machine.
- TPM works with TC-enabled software to assure that data it receives are trustworthy.
- Trusted Computing Services
  - Authenticated boot
  - Certification
  - Encryption

29

Trusted Computing

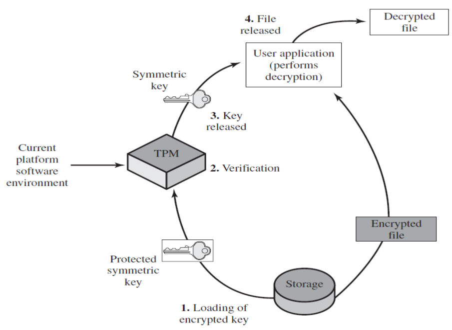
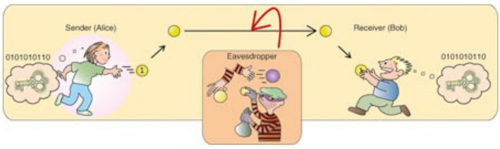


Figure 13.13 Decrypting a File Using a Protected Key

30

Key Management and Key Distribution

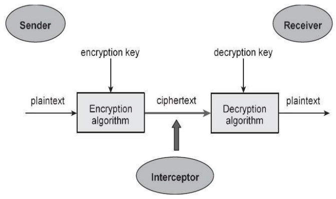
- Complex,
- Involve cryptographic mechanisms,
- Contain protocols,
- Management considerations



31

Key Management and Key Distribution
Symmetric Key Distribution with Symmetric Key

- Two parties to an exchange must share the same key
- Key must be protected from access by others
- Frequent key change is required



32

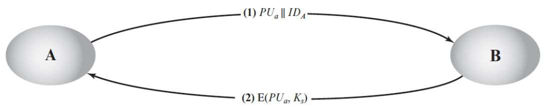
Key Management and Key Distribution
Symmetric Key Distribution with Asymmetric Key

- Public-key cryptosystems (PKC) are inefficient therefore they are almost never used for the direct encryption of sizable blocks of data.
- PKCs are limited to relatively small blocks.
- The most important uses of PKC is to encrypt secret keys for distribution.

33

Key Management and Key Distribution
Symmetric Key Distribution with Asymmetric Key

Simple Scenario



Problem: man-in-the-middle-attack possible

34

Key Management and Key Distribution
Public Keys Distribution

General Public Keys Distribution Schemes

- Public announcement
- Publicly available directory
- Public-key authority
- Public-key certificates

35

Key Management and Key Distribution
Public Keys Distribution - Public Announcement

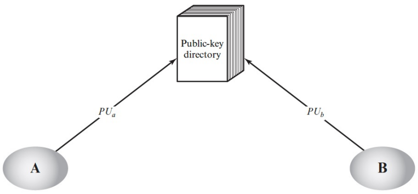
- Uncontrolled public key distribution
- A convenient approach
- Weakness: Anyone can forge such a public announcement
- PGP users have adopted the practice of appending their public key to messages that they send to public forums

36

Key Management and Key Distribution

Public Keys Distribution - Publicly Available Directory

- More secure than public announcements
- Weakness: If adversary obtains the private key of the directory authority, adversary authoritatively passes out counterfeit public keys and subsequently impersonate any participant and eavesdrop on messages sent to any participant.



37

Key Management and Key Distribution

X.509 Certificates

- ITU-T recommendation X.509 is part of the X.500 series of recommendations.
- Define a directory service.
- Directory is a server or distributed set of servers.
- Directory maintains a database of information about users.

38

Key Management and Key Distribution

Public Key Infrastructure

RFC 4949 (Internet Security Glossary) defines public-key infrastructure (PKI) as

- Set of hardware, software, people, policies, procedures
- Needed to create, manage, store, distribute, revoke digital certificates based on asymmetric cryptography.
- The principal objective for developing a PKI is to enable secure, convenient, and efficient acquisition of public keys.

39

Identity Management

- Identity information is mainly used for authentication purposes
- Steps of authentication
  1. Identification
  2. Verification

40

Identity Management

- Identity management is a centralized, automated approach to provide enterprisewide access to resources by employees and other authorized individuals.
- Focus of identity management is
  - defining an identity for each user (human or process),
  - associating attributes with the identity
  - enforcing a means by which a user can verify identity.
- The central concept of an identity management system is the use of single sign-on (SSO).

41

Identity Management

- SSO enables a user to access all network resources after a single authentication.
- Services provided by federated identity management
  - Point of contact: Includes authentication that a user corresponds to user name provided, and management of user/server sessions.
  - SSO protocol services: Provides a vendor-neutral security token service for supporting a single sign on to federated services.
  - Trust services: A trust relationship-based federation between business partners.
  - Key services: Management of keys and certificates.

42

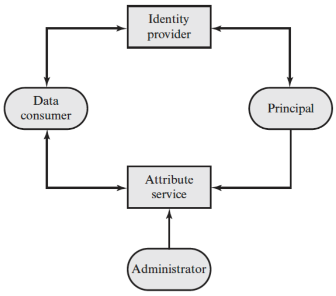
Identity Management

- Services provided by federated identity management (cont.)
  - Identity services: Services that provide the interface to local data stores
  - Authorization: Granting access to specific services and/or resources based on the authentication.
  - Provisioning: Includes creating an account in each target system for the user.
  - Management: Services related to runtime configuration and deployment.

43

Identity Management

Generic Identity Management Architecture



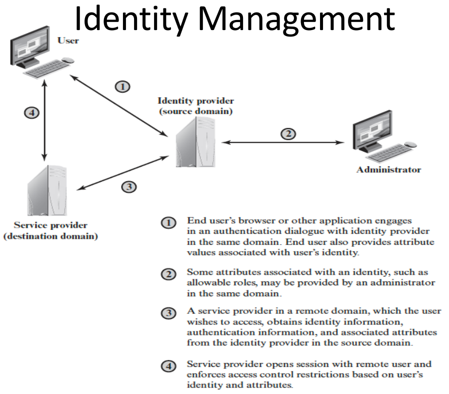
44

Identity Management

- Principal is an identity holder
- Identity provider associates authentication information with a principal, as well as attributes and one or more identifiers.
- Attribute service manages the creation and maintenance of such attributes.
- Administrators assign attributes to users, such as roles, access permissions, and employee information.
- Data consumers are entities that obtain and employ data maintained and provided by identity and attribute providers

45

Identity Management



46

Summary

- Trust definition
- Security and trust
- Properties of trust
- Trust models
- Key management and key distribution
- Identity management

47

Questions?

48